

Linux & Windows Hardening

The Principle of Least Privilege

Give every user and process the minimum privilege needed. Root/SYSTEM for nothing that doesn't need it. Admin accounts are the keys to the kingdom – an attacker who gets one has the kingdom.

The Hardening Mindset

"Assume compromise." Remove what you don't need, minimize what you keep, and log everything you can't remove.

Linux Hardening Checklist

```
# 1. Update/patches
apt update && apt upgrade -y      # never skip this

# 2. Remove unnecessary services
systemctl disable --now cups      # (example – adjust)

# 3. SSH hardening
sed -i 's/^#PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
sed -i 's/^#PasswordAuthentication.*/PasswordAuthentication no/' /etc/ssh/sshd_config

# 4. Firewall default-deny
ufw default deny incoming
ufw allow OpenSSH
ufw enable

# 5. Fail2ban for brute force
apt install fail2ban
```

SSH: disable password auth, use keys, disable root login. Fail2ban bans IPs that repeatedly fail.

Windows Hardening Checklist

```
# 1. Enable logging (crucial for detection)
# (Device Guard/Defender, Sysmon for process/network detail)

# 2. Disable unnecessary services & features
```

```
# (e.g., SMBv1 – the WannaCry vector via EternalBlue)
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol
# 3. Least privilege: users are Users, not Administrators
# 4. LAPS for local admin passwords (unique per machine)
# 5. Update management: WSUS/Intune patching with a test ring
```

The CIS Benchmarks

Center for Internet Security (CIS) publishes free hardening benchmarks for every OS, browser, DB, and cloud platform. Professionals implement "grey-box" hardening – following benchmarks then trimming for their environment.

STIGs (from the US DoD) are the strictest reference.

Patching Cadence & Risk-Based Patching

Not all patches are equal:

Critical (CVSS ≥ 9.0) – patch within days

High – within a week or two

Medium – within a month

Exploitability matters more than CVSS alone: if an exploit is public (or "weaponized" per EPSS), move it to the top.

Why Hardening Alone Isn't Enough

Hardening reduces the attack surface – but you must also detect the attempts that get through. Layers: hardening + AV/EDR + firewalls + SIEM + plans + people. Defense in depth.

[← Authentication, Passwords & ...](#)

Module complete ✓